GCVE-BCP-07 - Known Exploited Vulnerability (KEV) Assertion and No Known Exploitable Vulnerability (NKEV) Assessment Format

GCVE.eu

GCVE.eu

Contents

1 Known Exploited Vulnerability (KEV) Assertion and No Known Exploitable Vulnerability (NKEV) Assessment Format 1

2 Introduction 3

3 Known Exploited Vulnerability (KEV) Assertion Format 5

3.1 Usage Consideration . . . 5

3.1.1 Relationship between KEV and NKEV . . . 6

3.2 Format . . . 7

3.2.1 Sample . . . 7

3.2.1.1 Combined KEV Assertion . . . 7

3.2.1.2 CISA KEV in BCP-07 Format . . . 9

3.2.1.3 Illustrative Honeypot KEV Assertion: Separating CVSS, Severity, and Confidence . . . 10

3.2.1.4 Withdrawn and Reasserted KEV Assertions . . . 11

3.2.2 Field Description . . . 12

3.2.2.1 `uuid` . . . 12

3.2.2.2 `vulnerability` Object . . . 12

3.2.2.2.1 `vulnerability.vulnId` . . . 12

3.2.2.2.2 `vulnerability.altId` . . . 13

3.2.2.3 `status` Object . . . 13

3.2.2.3.1 `status.exploited` . . . 13

3.2.2.3.2 `status.status_reason` . . . 13

3.2.2.3.3 `status.status_updated_at` . . . 13

3.2.2.4 `characteristics` Object . . . 14

3.2.2.4.1 `characteristics.remote_code_execution` . . . 14

3.2.2.4.2 `characteristics.authentication_required` . . . 14

3.2.2.4.3 `characteristics.local_access_required` . . . 14

3.2.2.4.4 `characteristics.severity` . . . 14

3.2.2.5 `timestamps` Object . . . 15

3.2.2.5.1 `timestamps.first_seen_at` . . . 15

3.2.2.5.2 timestamps.asserted_at . . . 15
3.2.2.5.3 timestamps.recorded_at . . . 16
3.2.2.5.4 timestamps.last_seen_at . . . 16
3.2.2.6 scope Object . . . 16
3.2.2.6.1 scope.observation_regions . . . 16
3.2.2.6.2 scope.victim_countries . . . 16
3.2.2.6.3 scope.sector . . . 16
3.2.2.6.4 scope.asset_exposure . . . 17
3.2.2.6.5 scope.notes . . . 17
3.2.2.7 evidence Array . . . 17
3.2.2.7.1 evidence[].type . . . 17
3.2.2.7.2 evidence[].signal . . . 17
Interpretation of exploitation signals . . . 17
3.2.2.7.3 evidence[].confidence . . . 18
3.2.2.7.4 evidence[].source . . . 20
3.2.2.7.5 evidence[].details . . . 20
3.2.2.7.6 evidence[].gcve . . . 20
gcve Object . . . 20
3.2.2.8 gcve Object . . . 21
3.2.2.8.1 gcve.origin_uuid . . . 21
3.2.2.8.2 gcve.gna . . . 21
3.2.2.8.3 gcve.object_uuid . . . 21

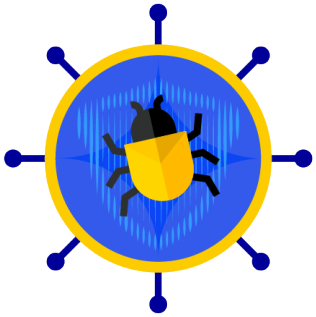
4 No Known Exploitable Vulnerability (NKEV) Assessment Format 23
4.1 NKEV Assessment Object . . . 23
4.1.1 NKEV Result Semantics . . . 24
4.1.2 Sample NKEV Assessment . . . 24
4.2 NKEV Field Description . . . 25
4.2.1 uuid . . . 25
4.2.2 assessment Object . . . 26
4.2.2.1 assessment.type . . . 26
4.2.2.2 assessment.result . . . 26
4.2.2.3 assessment.assessed_at . . . 26
4.2.2.4 assessment.knowledge_cutoff_at . . . 26
4.2.3 assessment.product Object . . . 27
4.2.3.1 assessment.product.vendor . . . 27
4.2.3.2 assessment.product.name . . . 27
4.2.3.3 assessment.product.version . . . 27

4.2.3.4 assessment.product.identifiers . . . 27
4.2.4 assessment.scope Object . . . 28
4.2.5 assessment.knowledge_sources Array . . . 28
4.2.6 assessment.evidence Array . . . 29
4.2.7 Relationship with VEX . . . 29
4.2.8 Referencing KEV Knowledge Sources from NKEV . . . 30
4.3 GCVE KEV Directory and Source Index Format . . . 30
4.3.1 Index Object . . . 31
4.3.2 Index Field Description . . . 31
4.3.2.1 kev Array . . . 31
4.3.2.2 kev[].uuid . . . 32
4.3.2.3 kev[].short_name . . . 32
4.3.2.4 kev[].gcve_gna_id . . . 32
4.3.2.5 kev[].url . . . 32
4.3.2.6 kev[].automation_url . . . 32
4.3.2.7 kev[].bcp_07_url . . . 32
4.3.2.8 kev[].description . . . 33
4.3.2.9 kev[].meta . . . 33
4.3.2.9.1 kev[].meta.license . . . 33
4.3.3 JSON Schema for the GCVE KEV Directory Array . . . 33
4.3.4 JSON Schema - KEV Assertion . . . 35
4.3.5 JSON Schema - NKEV Assessment . . . 43

5 References **51**

6 Acknowledgements **53**
6.1 BCP-07 Coordinators . . . 53
6.2 Contributions . . . 53

1 Known Exploited Vulnerability (KEV) Assertion and No Known Exploitable Vulnerability (NKEV) Assessment Format



GCVE.eu

- **Version**: 3.2
- **Status**: Draft
- **Date**: 2026-10-26
- **Authors**: GCVE Working Group
- **BCP ID**: BCP-07

This guide is distributed and available under CC-BY-4.0.

Copyright (C) 2025-2026 GCVE Initiative.

2 Introduction

Known Exploited Vulnerabilities (KEVs) have become a critical signal for vulnerability prioritization, operational risk management, and policy-driven remediation. Governments, CSIRTs, and sectoral authorities increasingly rely on KEV lists to mandate patching, trigger incident response, or inform compliance decisions. However, existing KEV publications are largely list-based and opaque, often asserting exploitation without clearly expressing who made the claim, when exploitation was observed versus declared, what type of evidence supports it, where it was seen, or with what level of confidence. As KEV data is increasingly consumed by automated systems and cross-border information-sharing mechanisms, the absence of structured, contextual metadata limits interoperability, trust calibration, and analytical reuse.

This Best Current Practice defines a standardized KEV assertion format that preserves the intentionally simple and binary nature of KEV while adding minimal but essential context. Within the GCVE or other ecosystem, where vulnerabilities may be disclosed and referenced by multiple independent authorities, exploitation claims must be clearly distinguishable from vulnerability identifiers and treated as attributable statements rather than universal truths. The format enables multiple, potentially conflicting assertions to coexist, supports explicit attribution and confidence signaling, and facilitates interoperability with existing vulnerability, CSIRT, and policy ecosystems without turning KEV into full threat intelligence or requiring disclosure of sensitive evidence.

Version 3.0 additionally defines a **No Known Exploitable Vulnerability (NKEV) assessment format**. An NKEV assessment is a product-level, time-bounded assertion that, within a declared scope and knowledge cutoff, the producer did not identify any known exploitable vulnerability from the vulnerability knowledge sources it consulted. NKEV is deliberately modeled as a sibling object type to KEV assertions: KEV describes a positive exploitation assertion about a vulnerability, while NKEV records a negative product-level knowledge assertion. NKEV is **not** a VEX statement and does not express a vulnerability-by-vulnerability applicability or exploitability decision for a particular product version.

3 Known Exploited Vulnerability (KEV) Assertion Format

This format describes a **generic KEV (Known Exploited Vulnerability) assertion format**.

The goal is to express *who claims exploitation*, *when*, *based on what*, *where it was observed*, and *with which level of confidence*, without turning KEV into full threat intelligence. A KEV assertion is usually very binary and lacking some meta-information. The format adds some information which could better capture details about the exploitation. A majority of the fields are optional except `vulnerability`, `status` and `evidence.[].source` which are recommended.

3.1 Usage Consideration

KEV and CVE (or GCVE) represent different layers in the model, and that distinction is intentional.

A vulnerability identifier (CVE/GCVE) is primarily about establishing the identity of a vulnerability something that the ecosystem can refer to consistently over time. KEV, on the other hand, is an assertion about observed exploitation activity, made by an observer at a given point in time. In an ideal world, the same actor that defines the vulnerability (for example, a vendor CNA) would also confirm exploitation, but in practice these concerns are frequently dissociated.

There are several common situations where vulnerability identity and exploitation assertions do not originate from the same place or even at the same time:

- Embargoed or restricted vulnerabilities, where exploitation is observed and tracked within a limited circle (CSIRTs, intelligence teams, trusted communities) before public disclosure or before a vendor-assigned identifier exists.
- Situations of disagreement or asymmetry of knowledge, where an observer has high-confidence evidence of exploitation while the vendor disputes impact, scope, or even the existence of the vulnerability.
- Early or partial observations, where exploitation activity is detected before a stable understanding of affected products, attack vectors, or vulnerability class has been established.

The KEV format explicitly models exploitation as an event-level assertion linked to a vulnerability identity, rather than as part of the identity itself. This reflects operational reality: exploitation is something that happens, may occur multiple times, may be observed by different parties, and may be interpreted differently as more information becomes available.

This separation already exists implicitly across today's KEV lists, vendor advisories, and threat intelligence reports, but it is inconsistently expressed, often duplicated, and rarely machine-parseable in a coherent way. The GCVE KEV format (BCP-07) provides a structured and open way to express these assertions while anchoring them to a shared vulnerability identifier when one exists.

Importantly, KEV entries are assertions, not ground truth.

They may later be revised, withdrawn, or contradicted by other observers. Decoupling identity from assertions allows such evolution without disconnecting from the underlying vulnerability record. A vulnerability identity should remain stable even if claims about exploitation change over time.

This model also assumes that multiple assertions per vulnerability identity are normal and expected. Different organisations may publish different KEV entries, CVSS scores, or detection signatures for the same GCVE ID, reflecting different perspectives, evidence sets, or confidence levels. Centralising identity while allowing plural assertions enables this diversity in a federated model.

With respect to identity-related data (such as vendor, product, or RCE status), once a vulnerability identity is established and assigned a GCVE ID, CVE ID (or any id), that identity should be the container for stable characteristics from a vendor. Assertions such as KEV entries, CVSS vectors, or signatures should primarily reference the GCVE ID, CVE ID (or any id) and focus on what is specific to the assertion itself: context, timing, confidence, evidence, or scoring rationale. The goal is not to repeat identity-defining attributes in every assertion.

Finally, this separation is essential for machine-readability. Clear boundaries between identity and assertions enable automated correlation, reasoning, and downstream decision-making across heterogeneous data sources. GCVE KEV (BCP-07) treats exploitation knowledge as structured data, without overloading the vulnerability identity layer itself.

3.1.1 Relationship between KEV and NKEV

BCP-07 distinguishes three separate concepts:

1. **Vulnerability identity** establishes what vulnerability is being referenced, for example by a GCVE, CVE, GHSA, or another vulnerability identifier.
2. **KEV assertion** states that a producer has observed or otherwise asserts exploitation of a vulnerability.

3. **NKEV assessment** states that, for a declared product scope and knowledge cutoff, the producer did not identify a known exploitable vulnerability in the knowledge sources it consulted.

A KEV assertion and an NKEV assessment are therefore not simple logical opposites. The absence of a KEV assertion **MUST NOT** be interpreted as an NKEV result. Likewise, `status.exploited` set to `false` **MUST NOT** be interpreted as an NKEV statement. In a KEV assertion, `exploited: false` only describes the current state of that producer's exploitation assertion, for example following a withdrawal.

NKEV is a **negative knowledge assertion**, not a VEX-style exploitability determination. It does not state that every vulnerability associated with a particular product version has been individually analysed and proven non-exploitable. Product names, release identifiers, versions, or configurations **MAY** be included to scope the assertion, but they do not change NKEV into a per-vulnerability applicability analysis.

An NKEV assessment is always scoped and time-bounded. A result of `pass` means that no known exploitable vulnerability was identified **within the declared scope, against the declared knowledge sources, and up to the declared knowledge cutoff time**. It does not mean that no vulnerability exists, that a specific vulnerability has been proven non-exploitable in a specific product version, that future exploitation is impossible, or that a product is automatically compliant with any legal or regulatory framework.

3.2 Format

It's a single JSON object (ECMA 404) per KEV entry. The KEV entry is associated to a vulnerability ID in GCVE ID or any known vulnerability identifier.

3.2.1 Sample

3.2.1.1 Combined KEV Assertion

The JSON file below provides an example of a KEV file referencing a GCVE vulnerability ID.

```
{
"vulnerability": {
    "vulnId": "GCVE-0-2025-55182"
  },
 "status": {
    "exploited": true,
    "status_reason": "confirmed",
    "status_updated_at": "2025-12-24T10:15:00Z"
```

```
  },
  "characteristics": {
    "remote_code_execution": true,
    "authentication_required": false,
    "local_access_required": false
  },
  "timestamps": {
    "first_seen_at": "2025-12-03T10:15:00Z",
    "asserted_at": "2025-12-05T12:10:11Z",
    "recorded_at": "2025-12-05T13:15:00Z",
    "last_seen_at": "2025-12-24T09:42:21Z"
  },
  "scope": {
    "observation_regions": ["Europe", "North America"],
    "victim_countries": ["LU","BE", "US", "CA"],
    "sector": ["Telecoms", "Aerospace"],
    "asset_exposure": ["internet-facing"],
    "notes": "Regions reflect observed evidence, not global exclusivity."
  },
 "evidence": [
    {
      "type": "incident_response",
      "signal": "confirmed_compromise",
      "confidence": 0.9,
      "source": "national-csirt",
      "details": {
        "observed_outcome": ["initial-access", "rce"],
        "detection_basis": ["forensics", "log-analysis"]
      }
    },
    {
      "type": "honeypot",
      "signal": "in_the_wild_attempts",
      "confidence": 0.6,
      "source": "research-honeynet",
      "details": {
        "attempt_volume": "high",
        "successful_exploitation": false
      }
    }
  ],
  "references": [
    {
      "id": "GCVE-0-2025-55182",
      "url": "https://vulnerability.circl.lu/vuln/CVE-2025-55182#sightings"
    }
  ]
}
```

3.2.1.2 CISA KEV in BCP-07 Format

The JSON file below provides an example of a KEV file referencing a CISA KEV assertion.

```
{
  "vulnerability": {
    "vulnId": "CVE-2020-29583"
  },
  "status": {
    "exploited": true,
    "status_reason": "confirmed",
    "status_updated_at": "2021-11-03T00:00:00Z"
  },
  "timestamps": {
    "first_seen_at": "2021-11-03T00:00:00Z",
    "asserted_at": "2021-11-03T00:00:00Z",
    "recorded_at": "2026-01-22T05:07:44Z"
  },
  "evidence": [
    {
      "type": "vendor_report",
      "signal": "successful_exploitation",
      "confidence": 0.8,
      "source": "cisa-kev",
      "details": {
        "feed": "CISA Known Exploited Vulnerabilities Catalog",
        "date_added": "2021-11-03",
        "due_date": "2022-05-03",
        "vendorProject": "Zyxel",
        "product": "Multiple Products",
        "vulnerabilityName": "Zyxel Multiple Products Use of Hard-Coded
            Credentials Vulnerability",
        "knownRansomwareCampaignUse": "Unknown",
        "cwes": [
          "CWE-522"
        ]
      }
    }
  ],
  "references": [
    {
      "id": "CVE-2020-29583",
      "url": "https://www.cisa.gov/known-exploited-vulnerabilities-
          catalog?search_api_fulltext=CVE-2020-29583"
    }
  ],
  "scope": {
    "notes": "KEV entry: Zyxel Multiple Products Use of Hard-Coded
        Credentials Vulnerability | Affected: Zyxel / Multiple Products
        | Description: Zyxel firewalls (ATP, USG, VM) and AP Controllers
         (NXC2500 and NXC5500) contain a use of hard-coded credentials
```

```
            vulnerability in an undocumented account (\"zyfwp\") with an
            unchangeable password. | Required action: Apply updates per
            vendor instructions. | Due date: 2022-05-03 | Known ransomware
            campaign use (KEV): Unknown | Notes (KEV): https://nvd.nist.gov/
            vuln/detail/CVE-2020-29583"
43    }
44  }
```

3.2.1.3 Illustrative Honeypot KEV Assertion: Separating CVSS, Severity, and Confidence

The following example illustrates the treatment of a vulnerability for which honeypot-based exploitation attempts have been reported. It is a **hypothetical normalization**, not an amendment to, or an independent verification of, the original producer's assertion. In particular, the illustrative confidence of `0.6` assumes that the reported requests have been reasonably attributed to the vulnerability; producers MUST assess their own evidence.

A CVSS score can be retained in `evidence[].details` as source metadata without being transformed into `characteristics.severity`. Where operational impact cannot be assessed from the evidence, the optional severity field is omitted.

```
{
  "vulnerability": {
    "vulnId": "CVE-2026-109618"
  },
  "status": {
    "exploited": true,
    "status_reason": "confirmed"
  },
  "scope": {
    "asset_exposure": ["internet-facing"],
    "notes": "Honeypot-based observations of exploitation attempts;
       successful victim compromise has not been established by this
       evidence."
  },
  "evidence": [
    {
      "type": "honeypot",
      "signal": "in_the_wild_attempts",
      "confidence": 0.6,
      "source": "shadowserver",
      "details": {
        "feed": "Shadowserver Foundation honeypot/exploited-
           vulnerabilities",
        "observation_date": "2026-10-22",
        "connections": 870,
        "vulnerability_score": 9.2,
        "vulnerability_severity": "Critical"
```

```
        }
      }
    ]
}
```

In this example, `status.status_reason: confirmed` refers to confirmation of the asserted attempt signal, **not** confirmation that an actual victim was compromised. A high CVSS score, or a large number of connections, does not by itself establish the severity of the observed operational impact.

3.2.1.4 Withdrawn and Reasserted KEV Assertions

A producer can stop standing behind its own KEV assertion by setting `status.exploited` to **`false`**, setting `status.status_reason` to `withdrawn`, and setting `status.status_updated_at` to the time of withdrawal. All three fields **MUST** be present in a withdrawn assertion. A withdrawn assertion is a tombstone: it records that the producer previously made the assertion and subsequently withdrew it. It does not prove that exploitation never occurred. It is distinct from `disputed`, which represents an assessment that the exploitation claim is contested, and from `historical`, which means the producer assesses that exploitation did occur in the past.

```
{
  "uuid": "1f47e98d-f850-4c2a-9e0f-c8dce5b0bdb1",
  "vulnerability": {
    "vulnId": "CVE-2026-69836"
  },
  "status": {
    "exploited": false,
    "status_reason": "withdrawn",
    "status_updated_at": "2026-09-09T14:00:00Z"
  },
  "scope": {
    "notes": "The asserting origin removed this vulnerability from its
       KEV catalogue."
  }
}
```

Producers **SHOULD** retain and publish a withdrawn assertion rather than delete it so that downstream mirrors can discover the withdrawal. When an assertion has a `uuid`, a producer **MUST** preserve that UUID during withdrawal. Evidence **MAY** be retained on a withdrawn record; when retained, it describes the evidence for the original claim and does not override the current `exploited: false` status.

Consumers **MUST** exclude every record with `status.exploited` set to **`false`** from the current KEV set by default, regardless of `status.status_reason`. The `withdrawn` reason additionally

tells consumers to retain the record as a tombstone for audit and reconciliation. Interpretation and retention of other false-status records are consumer-defined.

`status.exploited: false` **MUST NOT** be used to express an NKEV result. Product-level NKEV statements are represented by the separate NKEV assessment object defined later in this BCP. An NKEV result is a scoped negative knowledge assertion and not a per-vulnerability VEX or exploitability decision.

If the same producer later stands behind the assertion again, including for a recurrent source catalogue, it can reassert the record by setting `status.exploited` to **`true`**, choosing the applicable non-`withdrawn` `status_reason`, and advancing `status.status_updated_at`. It **MUST** preserve the UUID when one exists. On reassertion, the producer **SHOULD** advance `timestamps.asserted_at` to the new assertion time and **SHOULD NOT** change `timestamps.first_seen_at` unless new evidence establishes an earlier first observation. The record can move between asserted and withdrawn states repeatedly. BCP-07 represents the current state of that assertion; transports or repositories that require a complete transition history should retain successive versions of the record.

3.2.2 Field Description

3.2.2.1 `uuid`

- **Type:** string (UUID version 4)
- **Required:** no
- **Description:** A globally unique identifier (UUID), version 4, assigned to the KEV record.

3.2.2.2 `vulnerability` Object

Describes the vulnerability being asserted as exploited.

3.2.2.2.1 `vulnerability.vulnId`

- **Type:** string
- **Required:** yes
- **Description:** GCVE, CVE identifier, GHSA or any identifier of the vulnerability.
- **Example:** `"GCVE-0-2025-55182"`

3.2.2.2.2 `vulnerability.altId`

- **Type:** array
- **Required:** no
- **Description:** Alternative identifiers that refer to the same vulnerability, used in addition to `vulnerability.vulnId`.

3.2.2.3 `status` Object

Represents the current exploitation status.

3.2.2.3.1 `status.exploited`

- **Type:** boolean
- **Description:** Indicates whether exploitation has been observed or asserted.
- **Semantics:** A positive KEV assertion may be supported by verified exploitation attempts or by evidence of successful exploitation. It does not imply global prevalence, universal exploitability, successful exploitation, or victim compromise. Mere scanning or the availability of exploit code, without evidence of attempts attributable to the specific vulnerability, **SHOULD NOT** by itself establish a positive KEV assertion.

3.2.2.3.2 `status.status_reason`

- **Type:** string (enum)
- **Allowed values:** `confirmed`, `suspected`, `disputed`, `historical`, `unknown`, `withdrawn`
- **Description:** Rationale behind the exploitation status. `confirmed` signifies that the asserting producer considers the **stated exploitation assertion** sufficiently supported by its evidence. It **MUST NOT** be interpreted as `confirmed_compromise` unless the associated evidence supports that distinct outcome. In particular, confirmed attempts are not equivalent to confirmed successful exploitation.
- **Withdrawal semantics:** `withdrawn` means that the asserting origin no longer stands behind its own claim. When this value is used, `status.exploited` **MUST** be **`false`** and `status.status_updated_at` **MUST** be present. A later reassertion **MUST** set `status.exploited` to **`true`** and use an applicable non-`withdrawn` reason.

3.2.2.3.3 `status.status_updated_at`

- **Type:** string (RFC3339 datetime)

- **Description:** Timestamp of the last change to the exploitation status in the KEV assertion.

3.2.2.4 `characteristics` Object

Describes high-level technical characteristics of the vulnerability that are relevant to exploitation assessment, without providing exploit details or turning the KEV assertion into full threat intelligence.

Most of these fields describe technical properties of the vulnerability itself, not necessarily every observed exploitation instance. The optional `characteristics.severity` field is different: it describes the operational impact supported by this KEV assertion's exploitation evidence, and **MUST NOT** be treated as a copy of an intrinsic vulnerability severity score.

3.2.2.4.1 `characteristics.remote_code_execution`

- **Type:** boolean
- **Description:** Indicates whether successful exploitation can result in remote code execution.
- **Notes:** Does not imply exploit reliability or ease of weaponization.

3.2.2.4.2 `characteristics.authentication_required`

- **Type:** boolean
- **Description:** Indicates whether authentication is required to exploit the vulnerability.
- **Notes:** Reflects the weakest known exploitation path.

3.2.2.4.3 `characteristics.local_access_required`

- **Type:** boolean
- **Description:** Indicates whether local system access is required prior to exploitation.
- **Notes:** Useful to distinguish remote exploitation from post-compromise privilege escalation.

3.2.2.4.4 `characteristics.severity`

- **Type:** number (0–100)
- **Required:** no
- **Description:** An optional assessment, by the KEV producer, of the operational impact demonstrated by the exploitation evidence associated with this assertion. It is **not** an intrinsic vulnerability severity rating.

The severity value describes the observed or demonstrated consequences of exploitation, not the amount of malicious activity, the probability of exploitation, or the theoretical vulnerability impact.

- Producers **MUST NOT** automatically calculate or copy this value from CVSS (including multiplying a CVSS base score by 10), EPSS, or another vulnerability scoring system.
- Producers **SHOULD** base the value on evidence of exploitation outcomes, such as verified consequences in controlled environments or confirmed incidents affecting real systems. The supporting rationale **SHOULD** distinguish an outcome reproduced in a honeypot or test environment from operational impact confirmed at a victim organization.
- Scanning activity, the number of honeypot connections, or large volumes of attempted exploitation **MUST NOT**, on their own, be interpreted as evidence of high operational impact.
- A high value **MAY** be justified where a significant exploitation outcome, such as remote code execution or full system compromise, is technically demonstrated and attributed to the vulnerability, even without evidence of widespread compromise. Producers **SHOULD** explain the environment and limitations of that demonstration.
- When available evidence does not support an impact assessment, producers **SHOULD** omit `characteristics.severity` rather than infer a numerical value from CVSS, exploit-attempt counts, or another unrelated measure.
- Producers **SHOULD** document the impact evidence and rationale in `scope.notes` or `evidence[].details`.

Severity is independent of exploitation prevalence. A single verified exploitation event can demonstrate severe consequences, while thousands of attempts may not demonstrate their outcome. Consumers **MUST NOT** treat an absent severity value as zero, as an indication of harmlessness, or as a claim that the vulnerability itself has low severity.

BCP-07 does not prescribe a numerical conversion from observed impact to the 0–100 scale. Producers **SHOULD** disclose the assessment methodology when publishing this value and avoid unjustified numerical precision.

3.2.2.5 `timestamps` Object

Separates different notions of time to avoid ambiguity.

3.2.2.5.1 `timestamps.first_seen_at`

- **Type:** string (RFC3339 datetime)
- **Description:** Earliest known exploitation activity based on technical observation.
- **Notes:** May be estimated and updated retroactively.

3.2.2.5.2 `timestamps.asserted_at`

- **Type:** string (RFC3339 datetime)
- **Description:** Date when an authority or source officially declared exploitation.
- **Notes:** Mirrors fields such as “date added” in KEV lists.

3.2.2.5.3 `timestamps.recorded_at`

- **Type:** string (RFC3339 datetime)
- **Description:** Timestamp when this assertion was ingested or recorded by the collector.
- **Notes:** System-specific and independent of the source.

3.2.2.5.4 `timestamps.last_seen_at`

- **Type:** string (RFC3339 datetime)
- **Description:** Most recent confirmed observation of exploitation activity.
- **Notes:** Optional and often unavailable.

3.2.2.6 `scope` Object

Defines the observed context of exploitation.

3.2.2.6.1 `scope.observation_regions`

- **Type:** array of strings
- **Description:** Geographic regions where exploitation evidence was observed. The region can be described in **UN M49** format to facilitate automation.
- **Notes:** Reflects sensor or reporting coverage, not global limits.

3.2.2.6.2 `scope.victim_countries`

- **Type:** array of strings
- **Description:** Countries in ISO 3166 where confirmed victims were identified.
- **Notes:** Often incomplete or unavailable.

3.2.2.6.3 `scope.sector`

- **Type:** array of strings
- **Description:** Sectors targeted or affected by exploitation. The sector **SHALL** come from the MISP galaxy sector.
- **Example:** `"Telecoms"`, `"Aerospace"`

3.2.2.6.4 `scope.asset_exposure`

- **Type:** array of strings
- **Allowed values:** `internet-facing`, `internal`, `vpn-accessible`, `unknown`
- **Description:** Exposure context of affected assets.

3.2.2.6.5 `scope.notes`

- **Type:** string
- **Description:** Human-readable clarifications to prevent misinterpretation.

3.2.2.7 `evidence` Array

Collection of independent signals supporting the exploitation claim.

3.2.2.7.1 `evidence[].type`

- **Type:** string (enum)
- **Allowed values:** `incident_response`, `csirt_report`, `telemetry`, `honeypot`, `sinkhole`, `vendor_report`, `public_report`, `research_report`, `unknown`
- **Description:** Origin of the exploitation evidence.

3.2.2.7.2 `evidence[].signal`

- **Type:** string (enum)
- **Allowed values: (can be multiple)** `in_the_wild_attempts`, `successful_exploitation`, `confirmed_compromise`, `mass_scanning`, `weaponized_exploit_available`
- **Description:** Nature of the observed exploitation signal. A single evidence item may use one signal or an array of signals, as defined by the JSON Schema.

Interpretation of exploitation signals Exploitation signals represent distinct observation levels and **MUST NOT** be treated as interchangeable:

- `mass_scanning`: reconnaissance or scanning associated with a vulnerability, without sufficient evidence of a targeted exploitation attempt.
- `in_the_wild_attempts`: observable attempts directed at exploiting a specific vulnerability in an operational environment. This does **not** imply successful exploitation.

- `successful_exploitation`: evidence that an exploit successfully triggered the vulnerability and produced a verifiable exploitation outcome, including in an appropriately instrumented controlled environment. The environment **SHOULD** be documented.
- `confirmed_compromise`: evidence that exploitation resulted in compromise of an affected system or environment, with sufficient attribution to the vulnerability. A honeypot demonstration alone **MUST NOT** be represented as a confirmed compromise of a real victim.
- `weaponized_exploit_available`: evidence that a functional exploit is available; availability alone does **not** demonstrate exploitation in the wild.

`in_the_wild_attempts` **MUST NOT** be interpreted as proof of a successful exploit or victim compromise. Similarly, `successful_exploitation` does not imply widespread compromise or a large number of victims. Mere `mass_scanning` or `weaponized_exploit_available` signals, without additional evidence of attempts or exploitation, **SHOULD NOT** independently support `status.exploited: true`.

3.2.2.7.3 `evidence[].confidence`

- **Type:** number (0.0–1.0) or enum
- **Description:** Confidence in the accuracy and attribution of the *specific exploitation signal* in this evidence item. It does not score severity, the probability of successful exploitation, exploitation prevalence, or the number of compromised systems.

Confidence **SHOULD** reflect the specificity, traceability, quality, reproducibility, and corroboration of supporting observations. Producers **MUST NOT** determine confidence solely from `evidence[].type` or the reputation of the source. In particular, honeypot evidence is not automatically capped at `0.6`: high-confidence evidence may be available when payload inspection, instrumentation, controlled replay, or independent corroboration strongly supports the stated signal.

Conversely, generic scanning, incomplete logs, ambiguous probes, or traffic not reliably attributable to the specific vulnerability generally warrant lower confidence. Confidence in attempts **MUST NOT** be interpreted as confidence that exploitation succeeded.

Producers **SHOULD** describe their detection and attribution methodology, where possible, in `evidence[].details`. This is especially important for automatically generated or transformed KEV feeds. A producer **SHOULD** reassess confidence when the supporting evidence or signal changes, rather than automatically preserving a source-wide default.

The following table provides reference confidence levels. Numeric values **SHOULD** follow these reference points for consistency; intermediate values **MAY** be used when their rationale is documented. The examples are illustrative and do not prescribe fixed values solely by evidence type.

Confidence	Label	Meaning (confidence in this evidence item)	Typical exploitation evidence examples
0.0	None	No usable evidence or placeholder only	Empty claim; unresolved rumor with no traceability
0.1	Extremely low	Unreliable and uncorroborated; major gaps	Single anonymous post; vague claim of exploitation
0.2	Very low	Weak signal; high chance of misattribution	Ambiguous scanning activity; noisy or indirect telemetry
0.3	Low	Plausible but thin; limited traceability	Single non-authoritative report; partial indicators without artifacts
0.4	Low–moderate	Some structure and traceability; still uncertain	Reputable researcher hint with limited technical detail
0.5	Moderate	Credible but not fully validated; alternative explanations remain	Multiple consistent reports; exploitation attempts seen but success unclear
0.6	Moderate–high	Good evidence with reasonable verification	Honeypot payloads attributable to a specific vulnerability with reasonable technical validation; strong IOCs
0.7	High	Strong and fairly direct evidence; limited uncertainty	Validated honeypot captures, reproducible exploit attempts, or incident-response logs strongly supporting the stated signal
0.8	Very high	Direct evidence or strong multi-source corroboration	Forensics confirming exploit path; authoritative confirmation of in-the-wild exploitation
0.9	Near-certain	Highly direct, well-attributed, well-corroborated	Confirmed compromise with clear exploit attribution across independent sources

Confidence	Label	Meaning (confidence in this evidence item)	Typical exploitation evidence examples
1.0	Certain	Practically proven; no plausible alternative explanation	Deterministic proof (e.g., full packet/log capture) tying exploitation to the vulnerability

For honeypot evidence, `0.5` can describe plausible attempts requiring further verification; `0.6` can describe reasonably validated vulnerability-specific attempts; and `0.7` or higher can be justified by stronger technical validation or corroboration. These examples **MUST NOT** be used as automatic source-type mappings. In every case, the score refers to the actual `evidence[].signal` stated in the record.

3.2.2.7.4 `evidence[].source`

- **Type:** string
- **Description:** Logical text identifier of the reporting entity or data source such as `cisa-kev`.

3.2.2.7.5 `evidence[].details`

- **Type:** object
- **Description:** Structured, free-form metadata describing how the signal was derived. Additional feeds from KEV sources which are not described in this format such as `cwes`.
- **Notes:** Content is implementation-specific. Producers **SHOULD** document, when available, the observable payload or outcome, attribution method, whether an actual victim or only a controlled sensor was involved, and reasons supporting `evidence[].confidence`. Original CVSS values **MAY** be preserved here as source metadata but **MUST NOT** be converted automatically to `characteristics.severity`.

3.2.2.7.6 `evidence[].gcve`

- **Type:** object
- **Description:** Structured object describing evidence originating from the GCVE ecosystem.
- **Required:** no

`gcve` Object

- `evidence[].gcve.origin_uuid`

  - **Type:** string
  - **Description:** UUID of the origin instance where the assertion originated. GCVE maintains a list of known KEVs to determine the correct source UUID but the UUID **MUST** be consistent from the origin instance.

- `evidence[].gcve.gna`
  - **Type:** number (0–65535)
  - **Description:** GNA ID identifying the origin of the assertion.

- `evidence[].gcve.object_uuid`
  - **Type:** string
  - **Description:** UUID of the assertion associated with this evidence in the GCVE ecosystem.

3.2.2.8 `gcve` Object

- **Type:** object
- **Description:** Structured object describing evidence originating from the GCVE ecosystem at root level.
- **Required:** no

3.2.2.8.1 `gcve.origin_uuid`

- **Type:** string
- **Description:** UUID of the origin instance where the assertion originated. GCVE maintains a list of known KEVs to determine the correct source UUID but the UUID **MUST** be consistent from the origin instance.

3.2.2.8.2 `gcve.gna`

- **Type:** number (0–65535)
- **Description:** GNA ID identifying the origin of the assertion.

3.2.2.8.3 `gcve.object_uuid`

- **Type:** string
- **Description:** UUID of the assertion associated with this evidence in the GCVE ecosystem.

4 No Known Exploitable Vulnerability (NKEV) Assessment Format

The NKEV format describes a **product-level, time-bounded negative knowledge assertion**. It complements, but does not replace, KEV assertions.

A KEV assertion normally concerns one vulnerability and expresses that exploitation has been observed or asserted. An NKEV assessment starts from the product side and records that, within a declared product scope and up to a declared knowledge cutoff, the producer did not identify any vulnerability that its consulted sources classify or otherwise establish as known exploitable.

NKEV **MUST NOT** be interpreted as a VEX statement. In particular, an NKEV assessment does not express `affected`, `not_affected`, `fixed`, `under_investigation`, reachability, or other vulnerability-specific applicability or exploitability states. Those determinations belong in VEX, a vulnerability advisory, or another format designed for product-specific vulnerability analysis.

A product version, release identifier, configuration, or other product metadata **MAY** be included to make the scope of an NKEV assertion precise. Such scoping information identifies what the assertion covers; it **MUST NOT** be interpreted as proof that every vulnerability associated with that version or configuration was individually reviewed for exploitability.

An NKEV assessment **MUST NOT** infer a `pass` result merely from the absence of BCP-07 KEV assertions. The producer needs to consult and declare appropriate vulnerability knowledge sources. The NKEV result expresses the state of that knowledge review, not a detailed exploitability analysis of each vulnerability found in the product or its components.

4.1 NKEV Assessment Object

The NKEV assessment is a separate JSON object from a KEV assertion. Implementations **SHOULD** use a stable `uuid` for an assessment when the record is expected to be updated, redistributed, or reconciled across systems.

The core object is stored below the root `assessment` key and has `type` set to `nkev`.

4.1.1 NKEV Result Semantics

`assessment.result` uses the following values:

- `pass`: within the declared scope, knowledge sources, and knowledge cutoff, the producer did not identify any known exploitable vulnerability.
- `fail`: the producer identified at least one known exploitable vulnerability relevant to the declared product scope and therefore cannot make an NKEV assertion for that scope at that time.
- `inconclusive`: the producer could not make a sufficiently supported NKEV determination, for example because source coverage, product identification, or available evidence was incomplete.

These values represent **knowledge-assessment results**. They do not by themselves express legal conformity, certification, or regulatory compliance. A `pass` result also does not mean that all known vulnerabilities have been individually assessed as non-exploitable.

4.1.2 Sample NKEV Assessment

```
{
  "uuid": "3be2d7b8-8c6c-4a95-a8ad-4b95db4e8508",
  "assessment": {
    "type": "nkev",
    "result": "pass",
    "assessed_at": "2026-10-01T10:00:00Z",
    "knowledge_cutoff_at": "2026-10-01T09:30:00Z",
    "product": {
      "vendor": "Example Corp",
      "name": "Example Router",
      "version": "4.2.1",
      "identifiers": [
        {
          "type": "cpe",
          "id": "cpe:2.3:h:example:router:4.2.1:*:*:*:*:*:*:*"
        }
      ]
    },
    "scope": {
      "description": "Example Router release 4.2.1 as distributed by
         Example Corp.",
      "notes": "The version identifies the product release covered by
         the NKEV assertion; it does not imply a VEX-style per-
         vulnerability exploitability analysis."
    },
    "knowledge_sources": [
      {
        "type": "vulnerability_database",
```

```
        "name": "EUVD",
        "url": "https://euvd.enisa.europa.eu/",
        "queried_at": "2026-10-01T09:20:00Z"
      },
      {
        "type": "vulnerability_database",
        "name": "GCVE",
        "url": "https://db.gcve.eu/",
        "queried_at": "2026-10-01T09:21:00Z"
      },
      {
        "type": "vendor_advisory",
        "name": "Example Corp Security Advisories",
        "url": "https://example.invalid/security/",
        "queried_at": "2026-10-01T09:22:00Z"
      }
    ],
    "evidence": [
      {
        "type": "software_composition_analysis",
        "source": "assessment-toolchain",
        "tool": {
          "name": "ExampleSCA",
          "version": "2.4"
        }
      },
      {
        "type": "vulnerability_scan",
        "source": "assessment-toolchain",
        "tool": {
          "name": "ExampleScanner",
          "version": "5.1"
        }
      }
    ]
  },
  "gcve": {
    "origin_uuid": "1a89b78e-f703-45f3-bb86-59eb712668bd",
    "gna": 1,
    "object_uuid": "3be2d7b8-8c6c-4a95-a8ad-4b95db4e8508"
  }
}
```


4.2 NKEV Field Description

4.2.1 `uuid`

- **Type:** string (UUID version 4)

- **Required:** no
- **Description:** Stable identifier assigned to the NKEV assessment record.

4.2.2 `assessment` Object

- **Type:** object
- **Required:** yes
- **Description:** Contains the NKEV assessment itself.

4.2.2.1 `assessment.type`

- **Type:** string
- **Required:** yes
- **Allowed value:** `nkev`
- **Description:** Identifies the object as an NKEV assessment.

4.2.2.2 `assessment.result`

- **Type:** string (enum)
- **Required:** yes
- **Allowed values:** `pass`, `fail`, `inconclusive`
- **Description:** Overall result of the NKEV knowledge assessment.

A `pass` result is valid only for the declared product scope, knowledge sources, and assessment time. It **MUST NOT** be interpreted as a timeless statement, a legal conformity decision, or a VEX statement that individual vulnerabilities are non-exploitable in a specific product version.

4.2.2.3 `assessment.assessed_at`

- **Type:** string (RFC3339 datetime)
- **Required:** yes
- **Description:** Time at which the NKEV result was produced.

4.2.2.4 `assessment.knowledge_cutoff_at`

- **Type:** string (RFC3339 datetime)
- **Required:** yes

- **Description:** Latest point in time up to which vulnerability knowledge was considered by the assessment.

The knowledge cutoff makes the time-bounded nature of NKEV explicit. Consumers **MUST NOT** assume that a `pass` result remains valid after this timestamp without considering newer vulnerability knowledge.

4.2.3 `assessment.product` Object

Identifies the product or product family covered by the NKEV assertion.

4.2.3.1 `assessment.product.vendor`

- **Type:** string
- **Required:** no
- **Description:** Product vendor or project name.

4.2.3.2 `assessment.product.name`

- **Type:** string
- **Required:** yes
- **Description:** Product name.

4.2.3.3 `assessment.product.version`

- **Type:** string
- **Required:** no
- **Description:** Optional version or release identifier used to scope the NKEV assertion. Its presence does not imply that BCP-07 performed a vulnerability-by-vulnerability exploitability analysis of that version.

4.2.3.4 `assessment.product.identifiers`

- **Type:** array
- **Required:** no
- **Description:** Machine-readable identifiers for the product, product family, or release.

Each entry contains:

- `type`: identifier type such as `cpe`, `purl`, `swid`, `vendor`, or `other`.
- `id`: identifier value.

CPE or PURL are useful where available but neither is mandatory.

4.2.4 `assessment.scope` Object

Defines the product boundary to which the NKEV assertion applies.

The scope can contain:

- `description`: human-readable description of the product, release, build, distribution, or other boundary covered by the assertion.
- `notes`: additional limitations or assumptions.

The scope is used to identify what the NKEV statement covers. It is not a replacement for a VEX product status and does not encode vulnerability-specific applicability or exploitability.

4.2.5 `assessment.knowledge_sources` Array

- **Type:** array
- **Required:** yes
- **Description:** Vulnerability knowledge sources consulted when producing the NKEV assertion.

Each source contains:

- `type`: one of `vulnerability_database`, `kev_catalogue`, `vendor_advisory`, `upstream_advisory`, `csirt_advisory`, `research_source`, or `other`.
- `name`: human-readable source name.
- `url`: optional URI identifying the source.
- `queried_at`: RFC3339 timestamp recording when the source was consulted.
- `scope`: optional description of which part of the declared product scope the source was used for.

An NKEV result is meaningful only in relation to its declared knowledge sources. Implementations **SHOULD** use sources appropriate to the product category and **MAY** include BCP-07 KEV catalogues as one input source. A `pass` result **MUST NOT** be derived from the absence of a single KEV catalogue entry alone.

4.2.6 `assessment.evidence` Array

NKEV evidence records how the producer supported the negative knowledge assertion as a whole. It is intentionally not a list of VEX statements and does not carry per-vulnerability applicability or exploitability status.

Allowed evidence types include:

- `sbom`
- `binary_analysis`
- `software_composition_analysis`
- `vulnerability_scan`
- `authenticated_scan`
- `unauthenticated_scan`
- `source_code_analysis`
- `configuration_analysis`
- `vendor_statement`
- `manual_review`
- `test_result`
- `bcp07_kev_catalogue_check`
- `other`

An evidence item can contain:

- `source`: logical identifier of the producer or assessment source.
- `url`: optional URI for external evidence.
- `tool`: optional object with `name` and `version`.
- `reference`: optional object for referencing another record or source by `uuid`, identifier, or URI.
- `details`: implementation-specific structured metadata.

An SBOM or component inventory **MAY** be used as evidence to define or inspect product composition, but the existence of an SBOM **MUST NOT** by itself be interpreted as evidence that the product has no known exploitable vulnerabilities.

4.2.7 Relationship with VEX

NKEV and VEX answer different questions and **MUST NOT** be conflated.

- **NKEV** asks whether, within a declared product scope, set of knowledge sources, and time boundary, the producer can state that no known exploitable vulnerability was identified.

- **VEX** expresses vulnerability-specific product status, applicability, or exploitability information, typically for a particular vulnerability and one or more product versions or components.

BCP-07 therefore does not define, embed, or require VEX semantics in the NKEV object. A producer may maintain VEX documents separately as part of its vulnerability-management process, but an NKEV `pass` **MUST NOT** be interpreted as an implicit VEX `not_affected` or `not_exploitable` statement for any individual vulnerability. Conversely, the presence or absence of a VEX document does not by itself determine the NKEV result.

4.2.8 Referencing KEV Knowledge Sources from NKEV

An NKEV assessment can consult one or more KEV catalogues as knowledge sources when determining whether a known exploitable vulnerability has been identified for the declared product scope. Such a catalogue is one input among the knowledge sources used by the producer.

A KEV catalogue match does not make the NKEV object a VEX assessment. If product-specific analysis is required to determine whether a particular vulnerability applies to, or is exploitable in, a particular product version, that analysis is outside the NKEV format and should be expressed using an appropriate vulnerability advisory or VEX format.

4.3 GCVE KEV Directory and Source Index Format

BCP-07 describes individual KEV assertions, but implementers also need a way to discover which organisations publish KEV catalogues and where their machine-readable feeds are located. The GCVE initiative therefore maintains the GCVE KEV directory, a non-mandatory index in which KEV producers can announce their catalogues and exploitation assertions.

A KEV producer can be a vendor, a CSIRT, or any other organisation observing or reporting exploitation. Producers register a stable source entry in the directory and provide one of the following machine-readable endpoints:

- A `bcp_07_url` that directly publishes assertions in the BCP-07 format defined by this document.
- An `automation_url` that publishes a native KEV format. Where direct BCP-07 output is not available, a converter can transform that feed; the gcve-eu-kev project provides scripts and examples for such conversions.

Consumers and catalogue operators can use the directory to discover these distributed sources, retrieve or convert their assertions, and combine them into a more complete overview without treating

any single producer as the universal source of truth. One implementation of this aggregation workflow is the GCVE KEV catalogues overview, provided by Vulnerability-Lookup.

The index is a catalogue of KEV catalogues. It is not authoritative for the content of any listed catalogue and it is not required for a producer to publish BCP-07 KEV assertions. Its purpose is to facilitate discovery, correlation, and stable attribution of KEV catalogues, especially where `gcve.origin_uuid` or `evidence[].gcve.origin_uuid` values need to be resolved to a known source.

4.3.1 Index Object

The index is a single JSON object (ECMA 404) with a `kev` array. Each item in the array describes one KEV catalogue or source.

```
{
  "kev": [
    {
      "uuid": "1a89b78e-f703-45f3-bb86-59eb712668bd",
      "short_name": "CIRCL",
      "gcve_gna_id": 1,
      "url": "https://vulnerability.circl.lu/known-exploited-
         vulnerabilities-catalog",
      "automation_url": "https://vulnerability.circl.lu/api/kev/?
         vulnerability_lookup_origin=1a89b78e-f703-45f3-bb86-59
         eb712668bd",
      "bcp_07_url": "https://vulnerability.circl.lu/api/kev/bcp-07/?
         vulnerability_lookup_origin=1a89b78e-f703-45f3-bb86-59
         eb712668bd",
      "description": "CIRCL provides a known-exploited vulnerability
         catalog and supports the different status reasons described in
          GCVE BCP-07.",
      "meta": {
        "license": "CC-BY-4.0"
      }
    }
  ]
}
```

4.3.2 Index Field Description

4.3.2.1 kev Array

- **Type:** array
- **Required:** yes
- **Description:** Collection of KEV catalogue source descriptions.

4.3.2.2 `kev[].uuid`

- **Type:** string (UUID)
- **Required:** yes
- **Description:** Stable UUID identifying the KEV catalogue source. When a BCP-07 assertion uses `gcve.origin_uuid` or `evidence[].gcve.origin_uuid`, the value should match this UUID where the source is listed in the index.

4.3.2.3 `kev[].short_name`

- **Type:** string
- **Required:** yes
- **Description:** Short human-readable name for the KEV catalogue source.

4.3.2.4 `kev[].gcve_gna_id`

- **Type:** number (0–65535)
- **Required:** no
- **Description:** GNA ID associated with the source, when the source is a GCVE Numbering Authority or otherwise has an assigned GNA identifier.

4.3.2.5 `kev[].url`

- **Type:** string (URI)
- **Required:** yes
- **Description:** Human-facing URL for the KEV catalogue or source.

4.3.2.6 `kev[].automation_url`

- **Type:** string (URI)
- **Required:** no
- **Description:** Machine-readable URL for the source catalogue in its native or preferred automation format. This field may point to a format other than BCP-07.

4.3.2.7 `kev[].bcp_07_url`

- **Type:** string (URI)

- **Required:** no
- **Description:** Machine-readable URL where the KEV data can be retrieved in BCP-07 format. This field is optional because not every KEV source publishes BCP-07 directly. When present, consumers can prefer this URL over `automation_url` when they specifically need BCP-07 assertions.

4.3.2.8 `kev[].description`

- **Type:** string
- **Required:** no
- **Description:** Human-readable description of the KEV catalogue source.

4.3.2.9 `kev[].meta`

- **Type:** object
- **Required:** no
- **Description:** Optional metadata about the KEV catalogue source. This object is intentionally extensible to allow source-specific metadata without changing the core index format.

4.3.2.9.1 `kev[].meta.license`

- **Type:** string
- **Required:** no
- **Description:** Licence identifier for the KEV catalogue when available. SPDX identifiers SHOULD be used where an SPDX identifier exists, for example `CC-BY-4.0`, `CC0-1.0`, or `Apache-2.0`.

4.3.3 JSON Schema for the GCVE KEV Directory Array

The following schema validates only the array of source objects stored below the directory's top-level `kev` key. It does not validate the enclosing directory object.

```
{
  "$schema": "https://json-schema.org/draft/2020-12/schema",
  "$id": "https://gcve.eu/schemas/bcp-07-kev-directory-array.schema.
     json",
  "title": "GCVE-BCP-07 KEV Directory Array",
  "description": "The array of KEV catalogue sources stored below the
     directory's kev key.",
  "type": "array",
  "items": {
```

```
    "type": "object",
    "additionalProperties": false,
    "required": [
      "uuid",
      "short_name",
      "url"
    ],
    "properties": {
      "uuid": {
        "type": "string",
        "format": "uuid",
        "description": "Stable UUID identifying the KEV catalogue source."
      },
      "short_name": {
        "type": "string",
        "description": "Short human-readable name for the KEV catalogue source."
      },
      "gcve_gna_id": {
        "type": "integer",
        "minimum": 0,
        "maximum": 65535,
        "description": "GNA ID associated with the source, when available."
      },
      "url": {
        "type": "string",
        "format": "uri",
        "description": "Human-facing URL for the KEV catalogue or source."
      },
      "automation_url": {
        "type": "string",
        "format": "uri",
        "description": "Machine-readable URL for the source catalogue in its native or preferred automation format."
      },
      "bcp_07_url": {
        "type": "string",
        "format": "uri",
        "description": "Machine-readable URL where KEV data can be retrieved in BCP-07 format."
      },
      "description": {
        "type": "string",
        "description": "Human-readable description of the KEV catalogue source."
      },
      "meta": {
        "type": "object",
```

```
        "description": "Optional extensible metadata about the KEV
            catalogue source.",
        "additionalProperties": true,
        "properties": {
          "license": {
            "type": "string",
            "description": "Licence identifier for the KEV catalogue;
                use an SPDX identifier when available."
          }
        }
      }
    }
  }
}
```

4.3.4 JSON Schema - KEV Assertion

JSON Schema - GCVE-BCP-07 Known Exploited Vulnerability (KEV) Assertion Format.

```
{
  "$schema": "https://json-schema.org/draft/2020-12/schema",
  "$id": "https://gcve.eu/schemas/bcp-07-kev-assertion.schema.json",
  "title": "GCVE-BCP-07 Known Exploited Vulnerability (KEV) Assertion",
  "type": "object",
  "additionalProperties": false,
  "required": [
    "vulnerability",
    "status"
  ],
  "properties": {
    "vulnerability": {
      "type": "object",
      "additionalProperties": false,
      "required": [
        "vulnId"
      ],
      "properties": {
        "vulnId": {
          "type": "string",
          "description": "GCVE, CVE, GHSA or any identifier of the
              vulnerability."
        },
        "altId": {
          "type": "array",
          "description": "Alternative identifiers that refer to the
              same vulnerability, used in addition to vulnerability.
              vulnId.",
          "items": {
            "type": "string"
```

```
          }
        }
      }
    },
    "gcve": {
      "$ref": "#/$defs/gcveRoot",
      "description": "Structured object describing GCVE origin metadata for the KEV assertion."
    },
    "uuid": {
      "type": "string",
      "format": "uuid",
      "description": "Globally unique identifier (UUID v4) assigned to the KEV assertion record."
    },
    "status": {
      "type": "object",
      "additionalProperties": false,
      "allOf": [
        {
          "if": {
            "properties": {
              "status_reason": {
                "const": "withdrawn"
              }
            },
            "required": [
              "status_reason"
            ]
          },
          "then": {
            "properties": {
              "exploited": {
                "const": false
              }
            },
            "required": [
              "exploited",
              "status_updated_at"
            ]
          }
        }
      ],
      "properties": {
        "exploited": {
          "type": "boolean",
          "description": "Whether the producer currently asserts vulnerability-specific exploitation activity. This alone does not establish successful exploitation, victim compromise, or prevalence. Mere scanning or exploit availability alone should not be treated as a positive KEV
```

```
                assertion."
        },
        "status_reason": {
          "type": "string",
          "description": "Rationale behind the exploitation status.
             Confirmed refers to the producer's assertion, not
             necessarily confirmed compromise; interpret together with
             evidence.signal.",
          "enum": [
            "confirmed",
            "suspected",
            "disputed",
            "historical",
            "unknown",
            "withdrawn"
          ]
        },
        "status_updated_at": {
          "type": "string",
          "format": "date-time",
          "description": "Timestamp of the last change to the
             exploitation status in the KEV assertion (RFC3339)."
        }
      }
    },
    "characteristics": {
      "type": "object",
      "additionalProperties": false,
      "description": "High-level technical characteristics relevant to
         exploitation assessment.",
      "properties": {
        "remote_code_execution": {
          "type": "boolean",
          "description": "Whether successful exploitation can result in
              remote code execution."
        },
        "authentication_required": {
          "type": "boolean",
          "description": "Whether authentication is required to exploit
              the vulnerability."
        },
        "local_access_required": {
          "type": "boolean",
          "description": "Whether local system access is required prior
              to exploitation."
        },
        "severity": {
          "type": "number",
          "minimum": 0,
          "maximum": 100,
          "description": "Optional -0100 assessment of operational
```

```
                impact demonstrated by exploitation evidence. Not derived
                from CVSS, EPSS, scanning volume, or exploitation
                prevalence. Omit if impact cannot be assessed; absence
                does not mean zero."
          }
        }
      },
      "timestamps": {
        "type": "object",
        "additionalProperties": false,
        "description": "Separate notions of time to avoid ambiguity.",
        "properties": {
          "first_seen_at": {
            "type": "string",
            "format": "date-time",
            "description": "Earliest known exploitation activity based on
                technical observation (RFC3339)."
          },
          "asserted_at": {
            "type": "string",
            "format": "date-time",
            "description": "Date when an authority or source officially
               declared exploitation (RFC3339)."
          },
          "recorded_at": {
            "type": "string",
            "format": "date-time",
            "description": "Timestamp when this assertion was ingested/
               recorded by the collector (RFC3339)."
          },
          "last_seen_at": {
            "type": "string",
            "format": "date-time",
            "description": "Most recent confirmed observation of
               exploitation activity (RFC3339)."
          }
        }
      },
      "scope": {
        "type": "object",
        "additionalProperties": false,
        "description": "Observed context of exploitation.",
        "properties": {
          "observation_regions": {
            "type": "array",
            "description": "Geographic regions where exploitation
               evidence was observed (optionally UN M49).",
            "items": {
              "type": "string"
            }
          },
```

```
157           "victim_countries": {
158             "type": "array",
159             "description": "Countries (ISO 3166) where confirmed victims
                   were identified.",
160             "items": {
161               "type": "string",
162               "minLength": 2,
163               "maxLength": 2
164             }
165           },
166           "sector": {
167             "type": "array",
168             "description": "Sectors targeted/affected (SHALL come from
                   MISP galaxy sector).",
169             "items": {
170               "type": "string"
171             }
172           },
173           "asset_exposure": {
174             "type": "array",
175             "description": "Exposure context of affected assets.",
176             "items": {
177               "type": "string",
178               "enum": [
179                 "internet-facing",
180                 "internal",
181                 "vpn-accessible",
182                 "unknown"
183               ]
184             }
185           },
186           "notes": {
187             "type": "string",
188             "description": "Human-readable clarifications to prevent
                   misinterpretation."
189           }
190         }
191       },
192       "evidence": {
193         "type": "array",
194         "description": "Collection of independent signals supporting the
              exploitation claim.",
195         "items": {
196           "$ref": "#/$defs/evidenceItem"
197         }
198       },
199       "references": {
200         "type": "array",
201         "description": "Links/IDs referencing external resources about
              the vulnerability or sightings.",
202         "items": {
```

```
        "$ref": "#/$defs/reference"
      }
    }
  },
  "$defs": {
    "reference": {
      "type": "object",
      "additionalProperties": false,
      "required": [
        "id",
        "url"
      ],
      "properties": {
        "id": {
          "type": "string"
        },
        "url": {
          "type": "string",
          "format": "uri"
        }
      }
    },
    "confidence": {
      "description": "Confidence in the accuracy and attribution of the
          specific exploitation signal: a number -(0.01.0) or
        implementation-specific enum/string. Not a severity score,
        likelihood of exploit success, or count of compromised systems
        .",
      "oneOf": [
        {
          "type": "number",
          "minimum": 0,
          "maximum": 1
        },
        {
          "type": "string"
        }
      ]
    },
    "evidenceSignal": {
      "oneOf": [
        {
          "type": "string",
          "enum": [
            "in_the_wild_attempts",
            "successful_exploitation",
            "confirmed_compromise",
            "mass_scanning",
            "weaponized_exploit_available"
          ]
        },
```

```
        {
          "type": "array",
          "items": {
            "type": "string",
            "enum": [
              "in_the_wild_attempts",
              "successful_exploitation",
              "confirmed_compromise",
              "mass_scanning",
              "weaponized_exploit_available"
            ]
          },
          "minItems": 1,
          "uniqueItems": true
        }
      ]
    },
    "gcveEvidence": {
      "type": "object",
      "additionalProperties": false,
      "properties": {
        "origin_uuid": {
          "type": "string",
          "description": "UUID of the origin instance where the
             assertion originated."
        },
        "gna": {
          "type": "integer",
          "minimum": 0,
          "maximum": 65535,
          "description": "GNA ID identifying the origin of the
             assertion."
        },
        "object_uuid": {
          "type": "string",
          "description": "UUID of the assertion associated with this
             evidence in the GCVE ecosystem."
        }
      }
    },
    "gcveRoot": {
      "type": "object",
      "additionalProperties": false,
      "description": "GCVE metadata describing the origin and identity
         of the KEV assertion.",
      "properties": {
        "origin_uuid": {
          "type": "string",
          "format": "uuid",
          "description": "UUID of the origin instance where the KEV
             assertion originated."
```

```
        },
        "gna": {
          "type": "integer",
          "minimum": 0,
          "maximum": 65535,
          "description": "GNA ID identifying the origin of the KEV
             assertion."
        },
        "object_uuid": {
          "type": "string",
          "format": "uuid",
          "description": "UUID of the KEV assertion in the GCVE
             ecosystem."
        }
      }
    },
    "evidenceItem": {
      "type": "object",
      "additionalProperties": false,
      "required": [
        "source"
      ],
      "properties": {
        "type": {
          "type": "string",
          "description": "Origin of the exploitation evidence.",
          "enum": [
            "incident_response",
            "telemetry",
            "honeypot",
            "sinkhole",
            "vendor_report",
            "csirt_report",
            "public_report",
            "research_report",
            "unknown"
          ]
        },
        "signal": {
          "$ref": "#/$defs/evidenceSignal",
          "description": "Specific observation level (string or array
             of strings): scanning, exploitation attempts, successful
             exploitation, confirmed compromise, or exploit
             availability. Attempts do not imply success or victim
             compromise."
        },
        "confidence": {
          "$ref": "#/$defs/confidence"
        },
        "source": {
          "type": "string",
```

```
            "description": "Logical identifier of the reporting entity or
                data source."
          },
          "details": {
            "type": "object",
            "description": "Structured, free-form metadata describing how
                the signal was derived (implementation-specific).",
            "additionalProperties": true
          },
          "gcve": {
            "$ref": "#/$defs/gcveEvidence",
            "description": "Structured object describing evidence
               originating from the GCVE ecosystem."
          }
        }
      }
    }
}
```

4.3.5 JSON Schema - NKEV Assessment

JSON Schema - GCVE-BCP-07 No Known Exploitable Vulnerability (NKEV) Assessment Format.

```
{
  "$schema": "https://json-schema.org/draft/2020-12/schema",
  "$id": "https://gcve.eu/schemas/bcp-07-nkev-assessment.schema.json",
  "title": "GCVE-BCP-07 No Known Exploitable Vulnerability (NKEV)
     Assessment",
  "type": "object",
  "additionalProperties": false,
  "required": [
    "assessment"
  ],
  "properties": {
    "uuid": {
      "type": "string",
      "format": "uuid",
      "description": "Stable UUID assigned to the NKEV assessment
         record."
    },
    "assessment": {
      "$ref": "#/$defs/assessment"
    },
    "gcve": {
      "$ref": "#/$defs/gcveRoot"
    },
    "references": {
      "type": "array",
      "items": {
```

```
        "$ref": "#/$defs/reference"
      }
    }
  },
  "$defs": {
    "assessment": {
      "type": "object",
      "additionalProperties": false,
      "required": [
        "type",
        "result",
        "assessed_at",
        "knowledge_cutoff_at",
        "product",
        "knowledge_sources"
      ],
      "properties": {
        "type": {
          "const": "nkev"
        },
        "result": {
          "type": "string",
          "enum": [
            "pass",
            "fail",
            "inconclusive"
          ],
          "description": "Result of the scoped NKEV knowledge
             assessment; it is not a VEX or per-vulnerability
             exploitability status."
        },
        "assessed_at": {
          "type": "string",
          "format": "date-time"
        },
        "knowledge_cutoff_at": {
          "type": "string",
          "format": "date-time"
        },
        "product": {
          "$ref": "#/$defs/product"
        },
        "scope": {
          "$ref": "#/$defs/assessmentScope"
        },
        "knowledge_sources": {
          "type": "array",
          "minItems": 1,
          "items": {
            "$ref": "#/$defs/knowledgeSource"
          }
```

```
        },
        "evidence": {
          "type": "array",
          "items": {
            "$ref": "#/$defs/assessmentEvidence"
          }
        }
      }
    },
    "product": {
      "type": "object",
      "additionalProperties": false,
      "required": [
        "name"
      ],
      "properties": {
        "vendor": {
          "type": "string"
        },
        "name": {
          "type": "string"
        },
        "version": {
          "type": "string",
          "description": "Optional product version or release
             identifier used only to scope the NKEV assertion."
        },
        "identifiers": {
          "type": "array",
          "items": {
            "$ref": "#/$defs/identifier"
          }
        }
      }
    },
    "identifier": {
      "type": "object",
      "additionalProperties": false,
      "required": [
        "type",
        "id"
      ],
      "properties": {
        "type": {
          "type": "string",
          "enum": [
            "cpe",
            "purl",
            "swid",
            "vendor",
            "other"
```

```
            ]
          },
          "id": {
            "type": "string"
          }
        }
      },
      "assessmentScope": {
        "type": "object",
        "additionalProperties": false,
        "properties": {
          "description": {
            "type": "string"
          },
          "notes": {
            "type": "string"
          }
        }
      },
      "knowledgeSource": {
        "type": "object",
        "additionalProperties": false,
        "required": [
          "type",
          "name",
          "queried_at"
        ],
        "properties": {
          "type": {
            "type": "string",
            "enum": [
              "vulnerability_database",
              "kev_catalogue",
              "vendor_advisory",
              "upstream_advisory",
              "csirt_advisory",
              "research_source",
              "other"
            ]
          },
          "name": {
            "type": "string"
          },
          "url": {
            "type": "string",
            "format": "uri"
          },
          "queried_at": {
            "type": "string",
            "format": "date-time"
          },
```

```
        "scope": {
          "type": "string"
        }
      }
    },
    "assessmentEvidence": {
      "type": "object",
      "additionalProperties": false,
      "required": [
        "type",
        "source"
      ],
      "properties": {
        "type": {
          "type": "string",
          "enum": [
            "sbom",
            "binary_analysis",
            "software_composition_analysis",
            "vulnerability_scan",
            "authenticated_scan",
            "unauthenticated_scan",
            "source_code_analysis",
            "configuration_analysis",
            "vendor_statement",
            "manual_review",
            "test_result",
            "bcp07_kev_catalogue_check",
            "other"
          ]
        },
        "source": {
          "type": "string"
        },
        "url": {
          "type": "string",
          "format": "uri"
        },
        "tool": {
          "$ref": "#/$defs/tool"
        },
        "reference": {
          "$ref": "#/$defs/assessmentReference"
        },
        "details": {
          "type": "object",
          "additionalProperties": true
        }
      }
    },
    "tool": {
```

```
        "type": "object",
        "additionalProperties": false,
        "required": [
          "name"
        ],
        "properties": {
          "name": {
            "type": "string"
          },
          "version": {
            "type": "string"
          }
        }
      },
      "assessmentReference": {
        "type": "object",
        "additionalProperties": false,
        "properties": {
          "uuid": {
            "type": "string",
            "format": "uuid"
          },
          "id": {
            "type": "string"
          },
          "url": {
            "type": "string",
            "format": "uri"
          }
        },
        "anyOf": [
          {
            "required": [
              "uuid"
            ]
          },
          {
            "required": [
              "id"
            ]
          },
          {
            "required": [
              "url"
            ]
          }
        ]
      },
      "reference": {
        "type": "object",
        "additionalProperties": false,
```

```
277         "required": [
278           "id",
279           "url"
280         ],
281         "properties": {
282           "id": {
283             "type": "string"
284           },
285           "url": {
286             "type": "string",
287             "format": "uri"
288           }
289         }
290       },
291       "gcveRoot": {
292         "type": "object",
293         "additionalProperties": false,
294         "description": "GCVE metadata describing the origin and identity
              of the NKEV assessment.",
295         "properties": {
296           "origin_uuid": {
297             "type": "string",
298             "format": "uuid"
299           },
300           "gna": {
301             "type": "integer",
302             "minimum": 0,
303             "maximum": 65535
304           },
305           "object_uuid": {
306             "type": "string",
307             "format": "uuid"
308           }
309         }
310       }
311     }
312   }
```

5 References

- GCVE BCP-07 defines separate KEV assertion and NKEV assessment objects with distinct semantics. NKEV is not a VEX format and does not encode per-vulnerability product applicability or exploitability decisions.
- `gcve-eu-kev` scripts - CISA KEV and ENISA CNW EUVD to GCVE BCP-07 Converter: https://github.com/gcve-eu/gcve-eu-kev

6 Acknowledgements

6.1 BCP-07 Coordinators

- Cédric Bonhomme, CIRCL
- Alexandre Dulaunoy, CIRCL

6.2 Contributions

The GCVE initiative gratefully acknowledges the substantial contributions from the following individuals via public review :

- ENISA - CSIRTs network CVD WG
- Howard Chu
- Xavier Claude
- Johannes Clos
- Darses
- Jerry Gamblin
- Jay Jacobs
- Lex0xF0C
- Lindsey Cerkovnik
- Eireann Leverett
- William Robinet
- Tony Rutkowski